

**Санкт-Петербургский государственный электротехнический
университет «ЛЭТИ» им. В.И. Ульянова (Ленина)**

Аналитическая обработка данных в задачах информационной безопасности

Санкт-Петербург
2026

Содержание

Глоссарий	4
1. Лекционный курс	6
1.1. Лекция 1: Основы ClickHouse	6
1.1.1. Определение	6
1.1.2. OLAP vs OLTP	6
1.1.3. Когда нужен ClickHouse	6
1.1.4. Взаимодействие с ClickHouse	7
1.1.5. Движки таблиц (Engines)	7
1.1.5.1. Основные группы движков	7
1.1.5.2. Семейство MergeTree	7
1.1.6. Merge — фоновый процесс объединения данных	7
1.1.7. Партиционирование	7
1.1.7.1. Типичные ошибки партиционирования	8
1.1.8. TTL — управление жизненным циклом данных	8
1.1.9. ORDER BY — физический порядок хранения	8
1.1.9.1. Проектирование ORDER BY	8
1.1.10. PRIMARY KEY	9
1.1.11. Проблема дублей и ReplacingMergeTree	9
1.1.11.1. Способы получить дедуплицированные данные	9
1.2. Лекция 2: RBAC и ABAC: модели управления доступом в ИБ	11
1.2.1. Зачем нужны модели управления доступом	11
1.2.2. RBAC: роль как единица администрирования	11
1.2.3. Иерархии ролей и разделение обязанностей	11
1.2.4. ABAC: политика на основе атрибутов	11
1.2.5. Инфраструктура принятия решений в ABAC	12
1.2.6. RBAC и ABAC: сравнительная перспектива	12
1.2.7. Комбинированный подход RBAC + ABAC	12
1.2.8. Типичные ошибки проектирования доступа	12
1.3. Лекция 3: Распределённый ClickHouse: шарды, реплики и координация	13
1.3.1. Координация: ZooKeeper и ClickHouse Keeper	13
1.3.2. Шарды и реплики	13
1.3.3. Локальные и распределённые таблицы	13
1.3.4. Путь записи и чтения	13
1.3.5. Операционные риски распределённого кластера	14
1.3.6. Практические ориентиры проектирования	14
2. Лабораторный практикум	15
2.1. Введение в лабораторный практикум	15
2.2. Лабораторная работа 1: RBAC в ClickHouse	16
2.2.1. Цель	16
2.2.2. Подготовка	16
2.2.3. Часть 1: Роли и привилегии	16
2.2.3.1. Задание	16
2.2.3.2. Контрольные вопросы	17
2.2.4. Часть 2: Row Policies	17
2.2.4.1. Задание	17
2.2.4.2. Контрольные вопросы	17
2.2.5. Часть 3: Квоты и ограничения (дополнительно, не обязательно)	17
2.2.5.1. Задание	17
2.2.5.2. Контрольные вопросы	17
2.2.6. Часть 4: Проверка модели доступа	17
2.2.6.1. Задание	17

2.2.6.2. Вывод	18
2.3. Лабораторная работа 2: Обезличивание персональных данных	19
2.3.1. Цель	19
2.3.2. Исходные данные	19
2.3.3. Часть 1: Наивный подход (ловушка)	19
2.3.3.1. Задание	19
2.3.4. Часть 2: Попытка через ReplacingMergeTree	19
2.3.4.1. Задание	19
2.3.5. Часть 3: Правильный подход — ETL-пайплайн	19
2.3.5.1. Задание	19
2.3.5.2. Вывод	20
2.4. Лабораторная работа 3: Аудит логов безопасности	21
2.4.1. Цель	21
2.4.2. Задание	21
2.4.2.1. Часть 1: Схема данных	21
2.4.2.2. Часть 2: Генерация событий	21
2.4.2.3. Часть 3: Аналитические запросы	21
2.4.2.4. Часть 4: Materialized Views для агрегации	21
2.4.2.5. Связь с архитектурой ClickHouse	21
2.5. Лабораторная работа 4: Private Set Intersection	22
2.5.1. Цель	22
2.5.2. Задание	22
2.5.2.1. Часть 1: Подготовка данных	22
2.5.2.2. Часть 2: Реализация PSI	22
2.5.2.3. Часть 3: Верификация	22
2.5.2.4. Связь с архитектурой ClickHouse	22

Глоссарий

Ad-hoc анализ — Разовые, незапланированные аналитические запросы для исследования данных или проверки гипотез. В отличие от регулярных отчётов, выполняются по требованию без предварительной настройки ETL-пайплайнов. Требует интерактивной производительности и гибкого SQL.

API — Application Programming Interface — программная абстракция, определяющая методы и протоколы взаимодействия между программными компонентами. Обеспечивает унифицированный доступ к функциональности системы посредством стандартизированных вызовов, скрывая детали внутренней реализации.

BI — Business Intelligence — технологии и практики сбора, интеграции, анализа и представления бизнес-информации. Включает инструменты для создания отчётов, дашбордов, визуализации данных и поддержки принятия управленческих решений на основе данных.

CDN — Content Delivery Network — географически распределённая сеть серверов для кэширования и доставки статического контента пользователям с минимальной задержкой.

Компонент — Единица вычисления либо хранения данных, имеющая явно определённый контракт взаимодействия (интерфейс) и набор зависимостей.

CPU-time — Среднее процессорное время на транзакцию; оценивается через число ядер и TPS (мс на транзакцию).

CRM — Customer Relationship Management — система управления взаимоотношениями с клиентами. Программное обеспечение для автоматизации стратегий взаимодействия с клиентами, включая продажи, маркетинг, техподдержку и аналитику клиентских данных.

DAU — Daily Active Users — количество уникальных пользователей, взаимодействовавших с системой за сутки.

СУБД — Система управления базами данных — комплекс программных средств для создания, модификации и управления данными в базе данных. Обеспечивает структурированное хранение, эффективный доступ, целостность данных и управление конкурентным доступом.

DML — Data Manipulation Language — операции над данными в БД: SELECT/INSERT/UPDATE/DELETE.

Эмбединг — Векторное представление объекта (текста, изображения, пользователя, товара), полученное моделью машинного обучения для измерения семантической близости через расстояния в векторном пространстве.

Индекс — Вспомогательная структура данных в системах управления базами данных, предназначенная для оптимизации производительности операций поиска и извлечения информации. Организует упорядоченное представление данных для существенного сокращения времени доступа к записям.

Ввод-вывод — Input/Output — совокупность механизмов и протоколов обмена данными между вычислительной системой и внешними устройствами или другими системами. Включает операции получения данных из источников и передачи результатов обработки, представляя критически важный компонент архитектуры компьютерных систем.

IOPS — I/O Operations Per Second — количество операций ввода-вывода (чтения/записи) в секунду на уровне диска.

IoT — Internet of Things — сетевое взаимодействие физических устройств с датчиками и контроллерами. Характеризуется высокой частотой передачи небольших порций данных (телеметрия, метрики).

Слой — Множество компонентов, объединённых общей ответственностью и уровнем абстракции, и участвующих в системе согласно установленным правилам межслойных зависимостей. Говорят что слой А зависит от слоя Б если хотя бы один компонент слоя А зависит от компонента слоя Б.

LLM — Large Language Model — большая языковая модель на основе нейронных сетей, обученная на огромных объёмах текстовых данных. Способна генерировать код, текст, отвечать на вопросы и выполнять задачи программирования на основе естественно-языковых промптов.

LOC — Lines of Code — метрика объёма программного кода, измеряемая количеством строк. Используется для оценки размера кодовой базы, сложности проекта и трудозатрат на разработку. Не включает пустые строки и комментарии при подсчёте физических строк (PLOC), либо учитывает только исполняемые инструкции при подсчёте логических строк (LLOC).

MAU — Monthly Active Users — количество уникальных пользователей за месяц.

Метаданные — Структурированная информация, описывающая свойства других данных: время создания, размер, тип, владелец, права доступа. Используется для индексирования и маршрутизации без чтения основного содержимого.

Морселизация — Техника параллельной обработки данных путём разбиения на небольшие фрагменты (morsels) фиксированного размера (обычно ~1024 строки). Каждый morsel обрабатывается независимо векторизованным движком, что обеспечивает эффективное использование CPU-кэшей и параллелизацию на уровне потоков.

OLAP — Online Analytical Processing — класс систем для аналитической обработки данных. Ориентирован на выполнение сложных агрегирующих запросов по большим объёмам данных, использует колоночное хранение для оптимизации производительности аналитики.

OLTP — Online Transaction Processing — класс систем обработки транзакций в реальном времени. Характеризуется большим количеством коротких транзакций (чтение, вставка, обновление, удаление), строковым хранением данных и требованиями к консистентности.

QPS — Queries Per Second — количество запросов к базе данных в секунду. Один HTTP-запрос может порождать несколько запросов к БД.

RPS — Requests Per Second — количество пользовательских запросов (например HTTP) в секунду.

Сессия — Логический контекст взаимодействия клиента с системой между множественными запросами. Хранит состояние пользователя: аутентификацию, корзину, настройки. Реализуется через cookies + серверное хранилище (Redis) или JWT-токены.

SLA — Service Level Agreement — соглашение об уровне обслуживания с количественными метриками: uptime (99.9% = 8.76 ч простоя/год), задержка (p99 < 200 мс).

Support — Служба поддержки и обработка обращений пользователей: тикеты, инциденты, запросы на возврат и консультации.

TPS — Transactions Per Second — количество транзакций БД в секунду.

Транзакция — Последовательность операций чтения и записи в базе данных, рассматриваемая как единая логическая единица работы. Гарантирует атомарность выполнения: либо все операции завершаются успешно и фиксируются (COMMIT), либо при ошибке все изменения откатываются (ROLLBACK).

1. Лекционный курс

1.1. Лекция 1: Основы ClickHouse

Эта лекция формирует базовый понятийный аппарат курса: где находится место ClickHouse в архитектуре данных, как устроено хранение в MergeTree и почему в OLAP-системах критичны правильные ключи сортировки, партиционирование и фоновые merge-процессы.

1.1.1. Определение

ClickHouse — это распределённая СУБД¹ с открытым исходным кодом, созданная для аналитической обработки запросов (OLAP²) и хранения больших объёмов данных. Изначально разработана в Яндексе для Яндекс.Метрики — системы веб-аналитики, обрабатывающей миллиарды событий в сутки.

ClickHouse оптимизирован для сложных аналитических запросов, дашбордов и отчётности с низкой латентностью. Это позволяет аналитикам и инженерам строить интерактивные витрины и системы мониторинга поверх петабайтных объёмов данных, сохраняя высокую производительность даже при большом числе конкурентных запросов.

1.1.2. OLAP vs OLTP

	OLTP	OLAP
Назначение	Быстрые короткие транзакции: вставка, обновление, чтение отдельных записей	Сложные аналитические запросы: агрегация, группировка, анализ больших объёмов исторических данных
Оптимизация	Минимальная задержка, высокая согласованность при большом числе одновременных пользователей	Максимальная пропускная способность, высокая скорость сканирования миллионов/миллиардов записей
Схемы	Нормализованные, строгие ограничения, строковое хранение	Денормализованные (звезда, снежинка), колоночное хранение
Примеры	Платежи, заказы, CRM ³ , банковские транзакции	BI ⁴ , дашборды, Ad-hoc анализ ⁵ запросы, мониторинг

Таблица 1. Сравнение OLTP и OLAP

1.1.3. Когда нужен ClickHouse

Подходит:

- Аналитика на больших объёмах данных (шардирование, горизонтальное масштабирование).
- Высокая скорость агрегирования.
- Интерактивные дашборды и мониторинг.
- Поточковая обработка — анализ данных в реальном времени.

Не подходит:

- Нужны полноценные транзакции (многотабличные ACID-транзакции, сложные BEGIN/COMMIT/ROLLBACK сценарии). Экспериментальная поддержка транзакций существует, но ограничена.

¹Система управления базами данных — комплекс программных средств для создания, модификации и управления данными в базе данных. Обеспечивает структурированное хранение, эффективный доступ, целостность данных и управление конкурентным доступом.

²Online Analytical Processing — класс систем для аналитической обработки данных. Ориентирован на выполнение сложных агрегирующих запросов по большим объёмам данных, использует колоночное хранение для оптимизации производительности аналитики.

³Customer Relationship Management — система управления взаимоотношениями с клиентами. Программное обеспечение для автоматизации стратегий взаимодействия с клиентами, включая продажи, маркетинг, техподдержку и аналитику клиентских данных.

⁴Business Intelligence — технологии и практики сбора, интеграции, анализа и представления бизнес-информации. Включает инструменты для создания отчётов, дашбордов, визуализации данных и поддержки принятия управленческих решений на основе данных.

⁵Разовые, незапланированные аналитические запросы для исследования данных или проверки гипотез. В отличие от регулярных отчётов, выполняются по требованию без предварительной настройки ETL-пайплайнов. Требуется интерактивной производительности и гибкого SQL.

- Маленькие датасеты (для этого есть DuckDB).

1.1.4. Взаимодействие с ClickHouse

ClickHouse поддерживает несколько протоколов доступа:

- **Нативный TCP-протокол** — максимальная производительность, используется clickhouse-client и большинством драйверов.
- **HTTP / HTTPS интерфейс** — удобен для интеграции с веб-приложениями и мониторингом.
- **MySQL / PostgreSQL wire protocol** — совместимость с существующими клиентами и инструментами.
- **JDBC / ODBC драйверы** — для Java-приложений и BI-инструментов.

Вне зависимости от выбранного протокола, общение происходит на обычном SQL:

```
SELECT t1.id, t2.name
FROM t1
JOIN t2 ON t1.id = t2.id
```

1.1.5. Движки таблиц (Engines)

Поведение таблицы полностью определяется выбранным движком (engine). Именно engine определяет:

- как данные физически хранятся на диске,
- можно ли выполнять merge,
- поддерживается ли репликация,
- как работает дедупликация,
- возможны ли TTL и мутации (UPDATE/DELETE).

Выбор engine — это архитектурное решение. Его нельзя легко изменить без полной пересборки таблицы.

1.1.5.1. Основные группы движков

MergeTree-семейство — используется в большинстве продакшн-кейсов. Предназначено для больших объёмов аналитических данных.

Log / TinyLog — простые движки без merge и индексов. Используются для временных таблиц и тестирования.

Distributed — логический движок для работы с шардами. Сам данные не хранит.

Special engines — Kafka, Buffer, Dictionary — используются для интеграций и потоковой обработки.

1.1.5.2. Семейство MergeTree

- **MergeTree** — базовый вариант.
- **ReplicatedMergeTree** — с репликацией между нодами.
- **ReplacingMergeTree** — дедупликация по ключу при merge.
- **SummingMergeTree** — агрегация числовых колонок при merge.
- **AggregatingMergeTree** — хранение агрегатных состояний.
- **Collapsing / VersionedCollapsingMergeTree** — хранение событий с отменами.

1.1.6. Merge — фоновый процесс объединения данных

INSERT в ClickHouse никогда не переписывает существующие данные — он создаёт новые части (parts). Merge — это фоновый процесс, который объединяет эти части.

Это не оптимизация, а фундаментальная часть архитектуры. Система предполагает, что:

- данные пишутся быстро (append-only),
- порядок и консистентность достигаются позже (при merge),
- аналитика допускает небольшую задержку в «идеальности» данных.

1.1.7. Партиционирование

Партиции — это логическое разбиение таблицы на независимые части (обычно по дате), задаваемое выражением PARTITION BY.

Партиции позволяют:

- быстро удалять данные (DROP PARTITION — мгновенная операция),

- ограничивать scope merge,
- эффективно применять TTL,
- ускорять запросы с фильтрами по ключу партиционирования.

1.1.7.1. Типичные ошибки партиционирования

Основная ошибка — слишком мелкие партиции (например, партиционирование по user_id или uuid).

Количество партиций	Оценка
Десятки – сотни	Норма
1–2 тысячи	Допустимо в редких случаях
Десятки тысяч	Плохо
Сотни тысяч и более	Катастрофа

Таблица 2. Рекомендации по количеству партиций на таблицу

1.1.8. TTL — управление жизненным циклом данных

TTL — механизм автоматического удаления или перемещения данных по времени без внешних задач. Работает только в MergeTree-движках.

Важно: TTL не удаляет данные сразу, а дожидается merge. Данные будут существовать дольше указанного срока. При необходимости можно вручную запустить OPTIMIZE TABLE ... FINAL.

TTL работает на уровне частей (parts), а не партиций. Если TTL совпадает с границей партиций и включена настройка ttl_only_drop_parts = 1, ClickHouse целиком удаляет части, в которых все строки истекли — это быстрая операция. Без этой настройки (по умолчанию выключена) удаляются отдельные строки через мутации, что значительно дороже.

```
CREATE TABLE events_optimized (
    event_date Date,
    user_id UInt64,
    event_type String,
    data String
) ENGINE = MergeTree()
PARTITION BY toYYYYMM(event_date)
ORDER BY (event_date, user_id)
TTL event_date + INTERVAL 3 MONTH;
```

1.1.9. ORDER BY — физический порядок хранения

ORDER BY в определении таблицы определяет физический порядок хранения данных на диске. Это **не** порядок вывода в SELECT — для этого нужен отдельный ORDER BY в запросе.

Если поле из WHERE совпадает с префиксом ORDER BY, ClickHouse:

- читает минимальное количество данных,
- эффективно использует min/max индексы (sparse index),
- существенно уменьшает I/O.

1.1.9.1. Проектирование ORDER BY

ORDER BY должен:

- соответствовать самым частым фильтрам,
- **начинаться с колонок низкой кардинальности** (ascending cardinality),
- учитывать типичные паттерны запросов.

Это противоположно интуиции из OLTP (где B-tree индексы выигрывают от высокой селективности первой колонки). В ClickHouse sparse index работает иначе: первая колонка использует бинарный поиск, а для последующих колонок применяется generic exclusion search, который эффективен только когда предыдущая колонка имеет мало уникальных значений (одно значение покрывает много гранул). Кроме того, низкая кардинальность ведущей колонки значительно улучшает сжатие.

```
-- Хорошо: event_type (5-10 значений) первым, затем user_id (миллионы)
ORDER BY (event_type, user_id, event_date);
```

```
-- Плохо: user_id первым -- высокая кардинальность ломает
-- эффективность sparse index для последующих колонок
ORDER BY (user_id, event_type, event_date);
```

1.1.10. PRIMARY KEY

PRIMARY KEY определяет разреженный индекс и **ничего больше**.

Ключевые отличия от OLTP-систем:

- **ПК не гарантирует уникальность** — дубли разрешены.
- ПК обязан быть **префиксом** ORDER BY.
- Если PRIMARY KEY не указан — автоматически равен ORDER BY.

```
-- PRIMARY KEY автоматически = (timestamp, server_id, level)
ORDER BY (timestamp, server_id, level);
```

```
-- Можно указать более короткий ПК для экономии памяти:
ORDER BY (timestamp, server_id, level, request_id)
PRIMARY KEY (timestamp, server_id);
-- level и request_id участвуют в сортировке, но не в индексе
```

1.1.11. Проблема дублей и ReplacingMergeTree

Поскольку PRIMARY KEY не гарантирует уникальность, а UPSERT отсутствует, для управления дублями используется ReplacingMergeTree.

```
CREATE TABLE users_replacing (
    user_id UInt64,
    name String,
    email String,
    updated_at DateTime
) ENGINE = ReplacingMergeTree(updated_at)
PRIMARY KEY user_id;
```

При вставке строки с тем же ключом дубли **сохраняются**:

```
INSERT INTO users_replacing VALUES
(1, 'Alice', 'alice@example.com', '2026-01-01 10:00:00');
INSERT INTO users_replacing VALUES
(1, 'Alice Updated', 'new@example.com', '2026-01-01 11:00:00');
```

```
-- Дубли видны!
SELECT * FROM users_replacing WHERE user_id = 1;
-- -> 2 строки
```

1.1.11.1. Способы получить дедуплицированные данные

1. **FINAL** — дедупликация «на лету» при чтении:

```
SELECT * FROM users_replacing FINAL;
```

2. **argMax** — ручная дедупликация через агрегацию:

```
SELECT
    user_id,
    argMax(name, updated_at) AS name,
    argMax(email, updated_at) AS email,
    max(updated_at) AS updated_at
FROM users_replacing
GROUP BY user_id;
```

3. **OPTIMIZE TABLE ... FINAL** — принудительный merge:

```
OPTIMIZE TABLE users_replacing FINAL;
-- После этого дубли физически удалены
```

4. **Materialized View** — дедупликация при вставке в отдельную таблицу.

1.2. Лекция 2: RBAC и ABAC: модели управления доступом в ИБ

В этой лекции рассматриваются базовые модели авторизации как независимый слой архитектуры безопасности. Фокус — не на конкретной СУБД, а на том, как формально и операционно проектировать управление доступом в корпоративных системах.

1.2.1. Зачем нужны модели управления доступом

Аутентификация отвечает на вопрос «кто это?», а авторизация — «что этому субъекту разрешено делать?». Ошибки именно в авторизации часто приводят к критическим инцидентам: утечке данных, эскалации привилегий, нарушению принципа минимально необходимых прав.

Для формального описания доступа обычно выделяют четыре сущности:

- **Субъект** — пользователь, сервис, процесс.
- **Объект** — таблица, файл, API-метод, запись.
- **Действие** — чтение, запись, удаление, администрирование.
- **Контекст** — время, сеть, устройство, уровень риска, окружение.

1.2.2. RBAC: роль как единица администрирования

RBAC (Role-Based Access Control) строится на идее, что права назначаются не напрямую пользователям, а ролям. Пользователь получает права через принадлежность к роли.

Сущность RBAC	Назначение
Пользователь	Человеческий или машинный субъект, выполняющий действия
Роль	Функция в организации: аналитик, администратор, оператор
Привилегия	Разрешённая операция над объектом
Сеанс	Активированный поднабор ролей пользователя

Таблица 3. Базовые сущности RBAC

Преимущество RBAC — управляемость: при кадровых изменениях обычно достаточно изменить состав ролей, не пересобирая матрицу прав для каждого пользователя.

1.2.3. Иерархии ролей и разделение обязанностей

В зрелых системах роли образуют иерархию: старшая роль наследует права младшей. Это снижает дублирование политик и упрощает сопровождение.

Отдельно вводятся ограничения класса SoD (Separation of Duties):

- **Статическое разделение обязанностей** — пользователь не может одновременно состоять в конфликтующих ролях (например, «инициатор платежа» и «утверждающий платеж»).
- **Динамическое разделение обязанностей** — конфликтующие роли можно иметь, но нельзя активировать в одной сессии или в рамках одной бизнес-операции.

С точки зрения ИБ именно SoD ограничивает риск внутреннего злоупотребления и снижает вероятность несанкционированных изменений без контроля.

1.2.4. ABAC: политика на основе атрибутов

ABAC (Attribute-Based Access Control) принимает решение на основе набора атрибутов и правил. В отличие от RBAC, доступ определяется не только «к какой роли относится субъект», но и «при каких условиях выполняется запрос».

Типичные классы атрибутов:

- **Subject attributes** — подразделение, должность, clearance, тип учётной записи.
- **Object attributes** — класс данных, владелец, метка конфиденциальности.
- **Action attributes** — тип операции (read/write/export).
- **Environment attributes** — время, IP-сегмент, геолокация, устройство.

Политика ABAC может выглядеть как логическое правило: «разрешить чтение данных уровня internal, если сотрудник из того же подразделения и запрос поступил из корпоративной сети в рабочее время».

1.2.5. Инфраструктура принятия решений в ABAC

Практическая реализация ABAC обычно раскладывается на компоненты:

- **PAP (Policy Administration Point)** — контур управления политиками.
- **PDP (Policy Decision Point)** — контур вычисления решения Permit/Deny.
- **PEP (Policy Enforcement Point)** — точка применения решения в прикладной системе.
- **PIP (Policy Information Point)** — источники атрибутов (HR, IAM, CMDB, MDM).

Такое разделение важно для аудита: можно отдельно контролировать, кто менял политику, по каким атрибутам было принято решение и где оно было применено.

1.2.6. RBAC и ABAC: сравнительная перспектива

Критерий	RBAC	ABAC
Основная единица	Роль	Атрибут + правило
Сложность внедрения	Ниже	Выше
Гибкость	Средняя	Высокая
Прозрачность для аудита	Высокая при корректной роли-модели	Зависит от качества политик и атрибутов
Типичный риск	Role explosion	Policy explosion и несогласованные атрибуты
Когда уместно	Стабильные бизнес-функции	Динамичный контекст доступа

Таблица 4. Сравнение RBAC и ABAC

1.2.7. Комбинированный подход RBAC + ABAC

На практике чаще применяется гибридная схема:

- RBAC задаёт грубые границы полномочий.
- ABAC накладывает контекстные ограничения поверх роли.

Пример: роль «аналитик» даёт право чтения витрин, а ABAC-политика ограничивает доступ только своим доменом данных, рабочим сегментом сети и допустимым временем доступа.

1.2.8. Типичные ошибки проектирования доступа

- Назначение прав напрямую пользователям в обход ролевой модели.
- Избыточные «универсальные» роли с административными правами.
- Отсутствие периодической ревизии ролей и атрибутов.
- Смешение бизнес-ролей и технических ролей без явной границы.
- Отсутствие трассировки решения авторизации в аудит-логах.

С инженерной точки зрения модель доступа считается зрелой только тогда, когда она одновременно масштабируема, проверяема и наблюдаема в эксплуатации.

1.3. Лекция 3: Распределённый ClickHouse: шарды, реплики и координация

Эта лекция фокусируется на том, как ClickHouse масштабируется за пределы одного узла. Цель — связать логические понятия кластера (шард, реплика, distributed-таблица) с практическими эффектами: пропускная способность, отказоустойчивость, сложность эксплуатации.

1.3.1. Координация: ZooKeeper и ClickHouse Keeper

ZooKeeper используется как координационная система в распределённых кластерах ClickHouse: репликация, распределённые DDL, синхронизация состояния. ZooKeeper — отдельный сервис на Java.

ClickHouse Keeper — более новая альтернатива, написанная на C++ и оптимизированная под ClickHouse. При прочих равных Keeper снижает операционную сложность кластера, поскольку использует единый технологический стек и лучше интегрирован с механизмами самой СУБД.

1.3.2. Шарды и реплики

ClickHouse для распределения данных использует два ключевых понятия.

Шард (shard) — часть общего набора данных. Каждый шард хранит собственный фрагмент таблицы. Например, при диапазонном разбиении логов за 12 месяцев:

- Шард 1: январь–апрель,
- Шард 2: май–август,
- Шард 3: сентябрь–декабрь.

Реплика (replica) — копия шарда для отказоустойчивости и балансировки чтения.

	Реплика 1	Реплика 2
Шард 1	Сервер A	Сервер B
Шард 2	Сервер C	Сервер D
Шард 3	Сервер E	Сервер F

Таблица 5. Пример топологии: 3 шарда x 2 реплики

Итоговое разделение ответственности:

- **Шарды** — горизонтальное масштабирование по данным и нагрузке.
- **Реплики** — отказоустойчивость и масштабирование чтения.

1.3.3. Локальные и распределённые таблицы

В кластере обычно используются два уровня таблиц.

1. **Локальные таблицы** (ReplicatedMergeTree) существуют на каждом узле и реально хранят данные:

```
CREATE TABLE events_local ON CLUSTER my_cluster (  
    id UInt64,  
    ts DateTime,  
    user_id UInt32  
) ENGINE = ReplicatedMergeTree(  
    '/clickhouse/tables/{shard}/events_local',  
    '{replica}'  
)  
PARTITION BY toYYYYMM(ts)  
ORDER BY (ts, user_id);
```

2. **Распределённая таблица** (Distributed) хранит только метаданные маршрутизации и проксирует запросы на локальные таблицы:

```
CREATE TABLE events_all ON CLUSTER my_cluster AS events_local  
ENGINE = Distributed(my_cluster, default, events_local, user_id);
```

1.3.4. Путь записи и чтения

При проектировании важно понимать, где именно выполняется операция:

- INSERT в локальную таблицу записывает данные сразу на конкретный шард.

- INSERT в Distributed-таблицу маршрутизирует строки по шару согласно sharding_key.
- SELECT из Distributed рассылает подзапросы по шардам, после чего инициатор агрегирует результат.

По этой причине стоимость запроса определяется не только сложностью SQL, но и сетевой топологией, равномерностью шардирования и объёмом межузловой передачи данных.

1.3.5. Операционные риски распределённого кластера

- **Skew данных** при неудачном sharding_key: часть шардов перегружена, часть простаивает.
- **Сетевые задержки** увеличивают latency распределённых агрегирующих запросов.
- **Долгие merge/мутации** на одной реплике могут вызывать рассогласование производительности между репликами.
- **Сложность DDL-изменений** возрастает: схемы и настройки должны применяться синхронно по всему кластеру.

1.3.6. Практические ориентиры проектирования

- Выбирать sharding_key, который распределяет данные равномерно и совпадает с основными паттернами запросов.
- Хранить «горячие» данные компактно, чтобы минимизировать межшардовые сканы.
- Использовать ON CLUSTER для схемной консистентности объектов.
- Планировать capacity с учётом не только объёма хранения, но и сетевого трафика между узлами.

С инженерной точки зрения распределённый ClickHouse — это баланс между скоростью аналитики, стоимостью инфраструктуры и управляемой сложностью эксплуатации.

2. Лабораторный практикум

2.1. Введение в лабораторный практикум

Практикум состоит из четырёх лабораторных работ на стыке аналитических баз данных и информационной безопасности. Лабораторные опираются на лекцию 1 (основы ClickHouse), лекцию 2 (модели управления доступом) и лекцию 3 (распределённая архитектура ClickHouse).

Ключевая идея, проходящая через все лабораторные: ClickHouse — это колоночная аналитическая СУБД, а не OLTP-система. Каждая работа подсвечивает конкретное следствие этой архитектуры для задач ИБ:

- **Лабораторная 1 (RBAC):** роли, Row Policies, квоты; мутации тяжёлые, поэтому разграничение прав на ALTER критически важно.
- **Лабораторная 2 (обезличивание):** нельзя просто UPDATE ПДн, нужен ETL-пайплайн; студент сталкивается с ReplacingMergeTree и понимает, что это не замена UPSERT.
- **Лабораторная 3 (аудит):** append-only природа — **фича** для логов безопасности, удалить следы сложно.
- **Лабораторная 4 (PSI):** иммутабельность данных усиливает изоляцию между участниками протокола.

2.2. Лабораторная работа 1: RBAC в ClickHouse

2.2.1. Цель

Развернуть ClickHouse (Docker), создать таблицу с тестовыми данными, настроить ролевую модель доступа: пользователи, роли, привилегии, Row Policies, квоты. Убедиться, что разграничение прав в OLAP-системе работает иначе, чем в OLTP.

2.2.2. Подготовка

1. Развернуть ClickHouse через Docker Compose.
2. Подключиться к серверу через clickhouse-client.
3. Создать таблицу events и наполнить тестовыми данными:

```
CREATE TABLE events (  
    event_id UInt32,  
    timestamp DateTime,  
    user_id UInt32,  
    department String,  
    event_type String,  
    status String  
) ENGINE = MergeTree()  
PARTITION BY toYYYYMM(timestamp)  
ORDER BY (department, event_type, timestamp);  
  
INSERT INTO events  
SELECT  
    number,  
    now() - randUniform(0, 90*24*3600),  
    rand() % 1000,  
    ['sales', 'engineering', 'support'][rand() % 3 + 1],  
    ['login', 'logout', 'access', 'modify', 'delete']  
        [rand() % 5 + 1],  
    ['ok', 'error', 'denied'][rand() % 3 + 1]  
FROM numbers(50000);
```

2.2.3. Часть 1: Роли и привилегии

2.2.3.1. Задание

1. Создать три роли с разным уровнем доступа:

```
CREATE ROLE analyst;  
CREATE ROLE ingester;  
CREATE ROLE admin;  
  
-- analyst: только чтение  
GRANT SELECT ON default.events TO analyst;  
  
-- ingester: только вставка  
GRANT INSERT ON default.events TO ingester;  
  
-- admin: полный доступ (включая ALTER = мутации)  
GRANT ALL ON default.* TO admin;
```

2. Создать пользователей и назначить роли:

```
CREATE USER viewer IDENTIFIED BY 'viewer123'  
    DEFAULT ROLE analyst;  
CREATE USER loader IDENTIFIED BY 'loader123'  
    DEFAULT ROLE ingester;  
CREATE USER superuser IDENTIFIED BY 'admin123'  
    DEFAULT ROLE admin;
```

3. Проверить привилегии — подключиться как viewer:

```
clickhouse-client --user viewer --password viewer123
```

- `SELECT count() FROM events` — работает.
- `INSERT INTO events VALUES (...)` — ошибка `Not enough privileges`.
- `ALTER TABLE events DELETE WHERE 1` — ошибка `Not enough privileges`.

2.2.3.2. Контрольные вопросы

- Чем `GRANT ALL` отличается от перечисления `GRANT SELECT, INSERT, ALTER`?
- Что произойдёт, если пользователю назначены две роли с конфликтующими правами?

2.2.4. Часть 2: Row Policies

2.2.4.1. Задание

1. Создать Row Policy — `viewer` видит только данные подразделения `sales`:

```
CREATE ROW POLICY sales_only ON events
  FOR SELECT USING department = 'sales'
  TO viewer;
```

2. Подключиться как `viewer` и выполнить:

```
SELECT department, count() FROM events GROUP BY department;
```

Результат: только строки `sales`. Остальные подразделения не видны.

3. Добавить вторую политику для другого пользователя:

```
CREATE USER eng_viewer IDENTIFIED BY 'eng123'
  DEFAULT ROLE analyst;
```

```
CREATE ROW POLICY eng_only ON events
  FOR SELECT USING department = 'engineering'
  TO eng_viewer;
```

4. Убедиться, что `eng_viewer` видит только `engineering`, а `viewer` — только `sales`.

2.2.4.2. Контрольные вопросы

- Чем Row Policy в ClickHouse отличается от VIEW с фильтром?
- Можно ли обойти Row Policy через подзапрос или JOIN?

2.2.5. Часть 3: Квоты и ограничения (дополнительно, не обязательно)

2.2.5.1. Задание

1. Настроить квоту для роли `analyst`:

```
CREATE QUOTA analyst_quota
  FOR INTERVAL 1 MINUTE MAX QUERIES 10,
  FOR INTERVAL 1 HOUR MAX RESULT_ROWS 100000
  TO analyst;
```

2. Подключиться как `viewer` и выполнить 11 запросов подряд — на 11-м получить ошибку `Quota exceeded`.
3. Настроить ограничение на уровне профиля:

```
CREATE SETTINGS PROFILE analyst_profile
  SETTINGS max_execution_time = 5,
           max_memory_usage = 100000000
  TO analyst;
```

4. Выполнить тяжёлый запрос от имени `viewer` и убедиться, что он прерывается по таймауту.

2.2.5.2. Контрольные вопросы

- Зачем нужны квоты в аналитической системе, если запросы только на чтение?
- Чем квоты отличаются от настроек профиля (`SETTINGS PROFILE`)?

2.2.6. Часть 4: Проверка модели доступа

2.2.6.1. Задание

1. Заполнить таблицу, подключаясь от имени каждого пользователя и проверяя каждую операцию:

Операция	viewer	loader	superuser
SELECT * FROM events	?	?	?
SELECT (видит все department?)	?	?	?
INSERT INTO events VALUES (...)	?	?	?
DROP TABLE events	?	?	?
11-й запрос за минуту (квота)	?	—	—

Таблица 6. Матрица доступа

1. Убедиться, что `system.query_log` фиксирует все действия всех пользователей, включая отклонённые запросы:

```
SELECT user, query, type, exception
FROM system.query_log
WHERE event_time > now() - INTERVAL 10 MINUTE
ORDER BY event_time DESC
LIMIT 20;
```

2.2.6.2. Вывод

RBAC в ClickHouse позволяет гранулярно разграничить доступ: от ролей и привилегий до фильтрации строк (Row Policies) и ограничения нагрузки (квоты). Все действия пользователей — включая отказы — аудируемы через `system.query_log`.

2.3. Лабораторная работа 2: Обезличивание персональных данных

2.3.1. Цель

Реализовать пайплайн анонимизации ПДн, по пути столкнувшись с тем, что привычный подход «просто обновить поля» в ClickHouse не работает.

2.3.2. Исходные данные

Синтетический датасет `raw_users` (10К строк): ФИО, email, телефон, дата рождения, город, сумма транзакций.

2.3.3. Часть 1: Наивный подход (ловушка)

2.3.3.1. Задание

1. Попробовать обезличить данные «на месте»:

```
ALTER TABLE raw_users
  UPDATE email = SHA256(email),
         phone = concat('***', substring(phone, -4))
 WHERE 1
```

2. Наблюдать за мутацией: `SELECT * FROM system.mutations WHERE is_done = 0`.
3. Замерить время выполнения.
4. Выполнить `SELECT` во время мутации — увидеть, что часть строк уже обезличена, а часть — ещё нет (частичная видимость).
5. Зафиксировать проблемы:
 - Мутация медленная и ресурсоёмкая.
 - Во время выполнения данные в неконсистентном состоянии.
 - Откатить мутацию нельзя.

2.3.4. Часть 2: Попытка через `ReplacingMergeTree`

2.3.4.1. Задание

1. Создать таблицу `users_replacing` на движке `ReplacingMergeTree(version)` с тем же ключом, что и `raw_users`.
2. Написать Python-скрипт, который:
 - Читает данные из `raw_users`.
 - Применяет анонимизацию (хеширование email, маскирование телефона).
 - Вставляет обезличенные строки в `users_replacing` с `version = 2`.
3. Выполнить `SELECT ... FROM users_replacing` — увидеть дубли (оригиналы с `version=1` и обезличенные с `version=2`).
4. Выполнить `SELECT ... FROM users_replacing FINAL` — увидеть только обезличенные строки.
5. Выполнить `OPTIMIZE TABLE users_replacing FINAL` — дожидаться физического слияния.
6. Зафиксировать проблемы:
 - `FINAL` замедляет запросы.
 - `OPTIMIZE ... FINAL` — тяжёлая операция, по сути аналог мутации.
 - Оригинальные данные физически остаются на диске до слияния — с точки зрения ИБ это плохо.

2.3.5. Часть 3: Правильный подход — ETL-пайплайн

2.3.5.1. Задание

1. Написать пайплайн на Python:
 - Чтение из `raw_users` (можно батчами через `LIMIT ... OFFSET` или `clickhouse-connect`).
 - Трансформация: маскирование ФИО, хеширование email (SHA-256 с солью), генерализация города (город -> регион), бакетирование возраста (25 -> «20–29»).
 - Запись в новую таблицу `anonymized_users` (обычный `MergeTree`).
2. Сравнить аналитику до и после анонимизации:
 - Распределение по регионам — должно сохраниться.

- Средняя сумма транзакций по возрастным группам — должна быть близка.
- Точный поиск по email — должен быть невозможен без знания соли.

2.3.5.2. Вывод

В OLAP-системах данные не «правят на месте», а перекладывают трансформированными. Это не ограничение, а архитектурный паттерн: исходные данные иммутабельны, каждая трансформация создаёт новый слой. Для ИБ это означает, что обезличивание — это ETL-задача, а не UPDATE.

2.4. Лабораторная работа 3: Аудит логов безопасности

2.4.1. Цель

Построить мини-SIEM на базе ClickHouse: сбор, хранение и анализ security-событий. Append-only природа ClickHouse здесь работает **в пользу** безопасности.

2.4.2. Задание

2.4.2.1. Часть 1: Схема данных

1. Спроектировать таблицу `security_events` на движке MergeTree с партиционированием по дате (`toYYYYMM(timestamp)`).
2. Поля: `timestamp`, `event_type`, `source_ip`, `user_id`, `action`, `status`, `details`.
3. Выбрать ключ сортировки, оптимальный для типичных аналитических запросов (поиск по времени, по IP, по типу события).

2.4.2.2. Часть 2: Генерация событий

1. Написать Python-генератор, который создаёт поток security-событий:
 - Логины (успешные/неуспешные), в том числе серии brute-force.
 - Доступ к ресурсам (разрешённый/запрещённый).
 - Изменения привилегий.
2. Загрузить 100K событий за «3 месяца».

2.4.2.3. Часть 3: Аналитические запросы

1. Обнаружение brute-force: найти IP-адреса с более чем N неудачных попыток логина за 5 минут.
2. Аномальная активность: пользователи с нетипично большим количеством действий ($> 3\sigma$ от среднего).
3. Эскалация привилегий: цепочки событий «логин -> изменение роли -> доступ к ресурсу» за короткий промежуток.

2.4.2.4. Часть 4: Materialized Views для агрегации

1. Создать Materialized View `mv_failed_logins_per_minute`, который автоматически агрегирует неудачные логины по минутам и IP-адресам.
2. Сравнить производительность запроса к сырым данным и к Materialized View.

2.4.2.5. Связь с архитектурой ClickHouse

Append-only природа MergeTree означает, что злоумышленник не может легко удалить следы из логов: DELETE — это мутация, которая оставляет записи в `system.mutations` и `system.query_log`. Materialized View — это не кэш, а отдельная таблица, куда данные попадают при вставке; удаление из исходной таблицы не удаляет агрегаты.

2.5. Лабораторная работа 4: Private Set Intersection

2.5.1. Цель

Реализовать упрощённый протокол Private Set Intersection (PSI) на основе Diffie-Hellman: две «организации» находят общих клиентов, не раскрывая свои полные базы.

2.5.2. Задание

2.5.2.1. Часть 1: Подготовка данных

1. Создать две таблицы в ClickHouse: `org_a_clients` и `org_b_clients` с частичным пересечением по идентификатору (email).
2. Каждая таблица — обычный MergeTree, 100K записей.

2.5.2.2. Часть 2: Реализация PSI

1. Реализовать на Python протокол PSI на эллиптических кривых (или упрощённый DH):
 - Организация А хеширует свои email на кривую и отправляет точки организации В.
 - Организация В делает то же и вычисляет общий секрет.
 - Пересечение определяется по совпадению результатов.
2. Оркестрация: Python читает данные из ClickHouse, выполняет криптографические операции, записывает результат обратно.

2.5.2.3. Часть 3: Верификация

1. Проверить корректность: результат PSI должен совпадать с INNER JOIN по открытым данным.
2. Измерить overhead протокола по сравнению с прямым JOIN.

2.5.2.4. Связь с архитектурой ClickHouse

Данные в таблицах иммутабельны: организация В не может модифицировать данные организации А, даже имея доступ к ClickHouse. Row Policies (из лабораторной работы 1) дополнительно изолируют доступ. Результаты PSI записываются в отдельную таблицу — append-only, с полной аудируемостью (из лабораторной работы 3).